

Security+ 2.4 · Password Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —

Password Attacks (7:15) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Password attacks exploit weak or reused credentials. Password spraying uses a single common password against many accounts to avoid lockout. Credential stuffing reuses passwords leaked from other breaches. Brute force tries all combinations (fast but detectable). Dictionary attacks use a list of common words. Rainbow tables use precomputed hashes and are defeated by salting. Defenses include MFA, password managers, account lockout policies, salted hashing with Argon2 or bcrypt, and monitoring for anomalous logins.

High-Yield Core Concepts Tested on Exam

- Password spraying: one weak password tried against many users to avoid lockout (low and slow).
- Brute force: tries all combinations; dictionary: uses a wordlist.
- Rainbow table: precomputed hash table; defeated by salting.
- Credential stuffing: reusing passwords leaked from other sites.
- Defense: MFA, password managers, lockout, salted hashing (Argon2/bcrypt), anomaly detection.

Exam Tips & Classic Scenarios

- 'single weak password tried against many accounts' = password spraying.
- 'pre-computed hash table' = rainbow table (defense: salting).
- 'reuse of leaked credentials' = credential stuffing.

Typical Exam Scenario: An attacker uses the password 'Password123!' against every user in the domain, staying under the lockout threshold. This is password spraying. Defenses include MFA and monitoring for distributed login attempts.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Password Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker tests leaked passwords from one site on MULTIPLE other sites (password reuse):

- A)** Credential stuffing
- B)** Pure brute force
- C)** Rainbow table
- D)** Vishing

2. MFA requires at least two authentication factors. Which combination represents genuine multi-factor authentication?

- A)** Password + PIN
- B)** Password + Physical token
- C)** Two types of biometrics
- D)** Security question + Password

3. The correct way to STORE user passwords:

- A)** Hash with salt (e.g., bcrypt)
- B)** Reversible AES encryption
- C)** Plaintext protected by firewall
- D)** Base64

4. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Password spraying: 1 weak password against many users (stealthy)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Password spraying: 1 weak password against many users (stealthy)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.4) exam, an analyst evaluates the following technical requirement: 'Brute force = try everything; dictionary = word list'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Brute force = try everything; dictionary = word list...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Rainbow table = precomputed hash — KILLED by SALTING'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Rainbow table = precomputed hash — KILLED by SALTING...
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Reuse of leaked passwords on other sites = credential stuffing.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Reuse of leaked passwords on other sites = credential stuffing...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'single weak password tried against many accounts' = password spraying. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'single weak password tried against many accounts' = password spraying

9. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'pre-computed hash table' = rainbow table (defense: salting). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'pre-computed hash table' = rainbow table (defense: salting)...

10. Corporate scenario (Password Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: attacker uses password Password123! on all domain users, avoiding lockout' = password spraying. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Scenario: 'attacker uses password Password123! on all domain users, avoiding lockout' = password spraying

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Credential stuffing.

✓ **Why it's correct:** Credential stuffing is a cyberattack in which the attacker uses lists of credentials (username and password pairs) obtained from data breaches on one site to attempt authentication on multiple other sites, exploiting the common practice of password reuse. The attack is automated and relies on large volumes of leaked credentials. It differs from pure brute force because it does not attempt to guess passwords but uses already known combinations. It is a topic in the Threats, Vulnerabilities, and Mitigations domain of Security+ (SY0-701), objective 2.4, which covers attack techniques.

✗ **Why the others are wrong:**

- *Pure brute force:* Pure brute force is an attack method that exhaustively tries all possible character combinations until it finds the correct password. In credential stuffing, the attacker does not test random combinations; they use credentials previously leaked and valid in another context. Brute force is computationally intensive and easily detected by account lockouts, while credential stuffing exploits password reuse and can be stealthier because the credentials are legitimate. Therefore, pure brute force does not describe the scenario of testing leaked passwords on multiple sites.
- *Rainbow table:* A rainbow table is a hash-cracking technique that uses precomputed tables of password hashes to reverse cryptographic hash functions. It is used when the attacker obtains password hashes and wants to discover the plaintext passwords. However, the statement describes the use of already leaked passwords (in plaintext or already cracked) to authenticate on other sites, not hash cracking. Rainbow tables do not directly apply to credential stuffing, which does not require breaking encryption but rather exploiting credential reuse.
- *Vishing:* Vishing is a form of social engineering that uses phone calls or voice messages to deceive victims and obtain confidential information, such as passwords or financial data. It does not involve automated testing of leaked credentials across multiple sites. The described scenario is clearly a technical automation attack, not a human persuasion interaction. Therefore, vishing does not apply to the context of credential stuffing, which is a mass attack based on credential lists.

2) B — Password + Physical token.

✓ **Why it is correct:** The combination ****Password + Physical token**** represents genuine multi-factor authentication because it combines two distinct factors: something you know (the password) and something you have (the physical token, such as a smart card, USB key, or OTP generator device). MFA requires combining at least two of the three classic factors: knowledge (something you know), possession (something you have), and inherence (something you are). In the CompTIA Security+ (SY0-701) syllabus, this distinction is fundamental to avoid false MFA, such as password + PIN, which are both from the same factor (knowledge).

✗ **Why the others are wrong:**

- *Password + PIN:* Password and PIN are both based on knowledge; that is, they represent the same authentication factor (something you know). Even if they are two different secrets, they do not constitute genuine MFA, as there is no combination of distinct factors. An attacker who obtains both (e.g., via keylogger or social engineering) compromises authentication. To be MFA, it is necessary to add a possession or inherence factor. Therefore, this option is incorrect.
- *Two types of biometrics:* Two types of biometrics (e.g., fingerprint and facial recognition) belong to the same factor: inherence (something you are). Although they are distinct methods, they do not constitute genuine MFA, as they do not combine different factors. MFA requires combining distinct categories (knowledge, possession, inherence). Additionally, biometrics can be problematic

if compromised (once leaked, they cannot be changed). Thus, this option does not meet the multi-factor requirement.

- *Security question + Password*: Security questions and passwords are both based on knowledge (something you know). The security question is often used as a second step, but it still belongs to the same factor. Therefore, it is not genuine MFA. Furthermore, security questions are vulnerable to social engineering attacks and can be discovered on social media. To be MFA, it would be necessary to add a possession or inherence factor. Thus, this combination is incorrect.

3) A — Hash with salt (e.g., bcrypt).

✓ **Why it is correct:** Secure storage of user passwords requires the use of slow cryptographic hash functions resistant to brute-force attacks, such as bcrypt, scrypt, or Argon2, combined with a unique random salt per user. The salt prevents precomputed table attacks (rainbow tables) and ensures that identical passwords produce different hashes. Functions like bcrypt are designed to be computationally expensive, adjustable by cost factor, making dictionary and offline brute-force attacks difficult. The hash is one-way, so even if the database is compromised, the attacker does not directly obtain the original password, only the hash, which must be cracked individually.

✗ **Why the others are wrong:**

- *Reversible AES encryption*: AES is a reversible symmetric cipher: with the correct key, the ciphertext can be decrypted back to plaintext. If passwords are stored encrypted with AES, anyone who obtains the encryption key (e.g., through compromise of the application server or database) can recover all original passwords. This violates the principle that not even system administrators should know user passwords. Additionally, AES key management adds unnecessary complexity and risk for data that never needs to be recovered in plaintext.
- *Plaintext protected by firewall*: Storing passwords in plaintext means they are readable in the database or configuration file. A firewall protects against unauthorized network access but does not prevent an attacker who exploits an application vulnerability, a malicious insider, or an administrator with database access from directly reading the passwords. Defense in depth requires that sensitive data be protected at rest, regardless of perimeter controls. A firewall is a network control, not a credential storage control.
- *Base64*: Base64 is a reversible encoding without a key, often used to represent binary data in text. It offers no confidentiality: anyone can decode a Base64 string instantly. Storing passwords in Base64 is functionally equivalent to storing them in plaintext, just with an obfuscated appearance. There is no salt, no computational cost, and no resistance to attacks. It is a completely inadequate practice for credential protection.

4) B — Implement the corresponding solution: Password spraying: 1 weak password against many users (stealthy)....

✓ **Why it is correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 2.4 (Password Attacks): Password spraying: 1 weak password against many users (stealthy). Password spraying is a type of brute-force attack where the attacker tries a single common weak password against many accounts, avoiding account lockout thresholds and remaining stealthy.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: Brute force = try everything; dictionary = word list....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Password Attacks): Brute force = try everything; dictionary = word list.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Rainbow table = precomputed hash — KILLED by SALTING....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Password Attacks): Rainbow table = precomputed hash — KILLED by SALTING. A rainbow table is a precomputed table of hash values used to crack password hashes. Salting adds random data to each password before hashing, making precomputed tables ineffective.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.

7) B — Implement the corresponding solution: Reuse of leaked passwords on other sites = credential stuffing....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Password Attacks): Reuse of leaked passwords on other sites = credential stuffing. Credential stuffing is an automated attack that leverages username/password pairs breached from one service to gain unauthorized access to other services where users have reused the same credentials. It exploits password reuse and is mitigated by unique passwords, password managers, MFA, and breach monitoring.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'single weak password tried against many accounts' = password spraying.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Password Attacks): 'single weak password tried against many accounts' = password spraying. This technique attempts a few common passwords across many accounts to avoid lockout policies, exploiting weak password practices.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'pre-computed hash table' = rainbow table (defense: salting)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Password Attacks): 'pre-computed hash table' = rainbow table (defense: salting). A rainbow table is a precomputed table of hash values used to crack password hashes. Salting, which adds random data to each password before hashing, defeats rainbow tables by making precomputed hashes ineffective.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: Scenario: 'attacker uses password Password123! on all domain users, avoiding lockout' = password spraying.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Password Attacks): Scenario: 'attacker uses password Password123! on all domain users, avoiding lockout' = password spraying. This technique tries a single weak password across many accounts to evade lockout thresholds, exploiting weak password policies.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.